PENSE-BÊTE · RECOMMANDATIONS DE SÉCURITÉ

Groupes Lockean, FIN12 et écosystème des rançongiciels

03-1190 CERT-FR - Groupes cybercriminels Lockean et FIN12 et écosystème des rançongiciels — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. Le groupe Lockean utilise une chaîne d'infection passant par la distribution de QakBot via Emotet ou TA551 pour mener des attaques de Big Game Hunting.
2. Le groupe FIN12 cible particulièrement le secteur de la santé et privilégie un chiffrement rapide, en environ quatre jours, recourant rarement à la double extorsion.
3. L'isolement du réseau peut permettre de stopper une attaque avant l'exfiltration des données ou le chiffrement des machines.

Synthèse du groupe Lockean

Notion	À retenir
Des incidents reliés	Identifié par l'ANSSI à partir de **6 incidents** français (**2020-2021**, QakBot : Gefco, Ouest-France, Fareva, Pierre Fabre…). Similitudes : nommage **QakBot**, serveurs **Cobalt Strike** (domaines Akamai/Azure), `Rclone` déguisé en `svchost`.
La chaîne d'infection	Distribution via **Emotet** puis **TA551** pour diffuser **QakBot** par hameçonnage. Latéralisation (**Cobalt Strike**), exfiltration (**Rclone**), chiffrement (**Maze**, **Egregor**, **ProLock**, **DoppelPaymer**, **Sodinokibi**) et **double extorsion**.
Un ciblage opportuniste	Logique de **Big Game Hunting** visant les entités françaises. Attaque de **Gefco** (détenu à **75 pour cent** par les chemins de fer russes), malgré l'interdiction de viser les pays de la **CEI**.

Synthèse des incidents et profils

Notion	À retenir
Incident CHU Brest	Le **9 mars 2023**, compromission via **RDP** (identifiants volés par **information stealer**). Déploiement de `SystemBC` et `Cobalt Strike`. L'isolement d'Internet a évité l'exfiltration et le chiffrement.
Profil de FIN12	**Pistachio Tempest** (Microsoft) : **Ryuk** puis **Conti** (2020-2023), puis RaaS **Hive**, **BlackCat**, **Nokoyawa**, Play, Royal. **Big Game Hunting**, **santé** (**≥ 20 %** des victimes), identifiants valides. Chiffrement rapide : **Time-To-Ransom ~4 jours** (intrusion → chiffrement) ; double extorsion **rare**.

Écosystème et parades

Notion	À retenir
Écosystème spécialisé	Répartition des rôles : **distribution**, **accès initial**, **latéralisation**, **chiffrement**, **extorsion**. Les affiliés changent de rançongiciel selon la **fragmentation des groupes** (ex: après la fin de **Conti**).
Les parades	**Ne pas exposer** de bureau à distance sur Internet ; protéger les identifiants par l'**authentification multifacteur** ; surveiller les outils détournés (**Cobalt Strike**, **Rclone**) ; **réagir vite** (l'isolement du réseau peut empêcher le chiffrement).

Pièges et confusions

- ⚠ Confondre l'usage de Rclone (exfiltration de données) avec celui de Cobalt Strike (pilotage de machines compromises).
- ⚠ Croire que FIN12 pratique systématiquement la double extorsion : il y recourt rarement et privilégie un chiffrement rapide.
- ⚠ Penser que le délai de rançon est le temps entre l'intrusion et l'extorsion alors qu'il s'agit du temps entre l'intrusion et le chiffrement.
- ⚠ Oublier que les identifiants volés par des information stealers constituent un vecteur d'accès majeur.
- ⚠ Confondre un service de distribution comme Emotet avec un chargeur comme QakBot.

Sigles et définitions

RaaS	Le rançongiciel en tant que service, met un rançongiciel à disposition d'affiliés contre une part des rançons.
Big Game Hunting	Cible de grandes organisations capables de payer des rançons élevées, après une préparation parfois de plusieurs mois.
Information stealer	Un code malveillant qui collecte les identifiants sur une machine compromise.
Cobalt Strike	Un outil commercial de test d'intrusion largement détourné pour piloter des machines compromises.
Rclone	Un outil libre de gestion de contenus dans le cloud, détourné pour exfiltrer des données.
Chargeur	Un loader, comme QakBot, prépare l'arrivée d'autres outils sur la machine infectée.

Auto-test

1. Combien d'incidents français ont permis d'identifier Lockean ?
2. Quel outil est utilisé par Lockean pour l'exfiltration de données ?
3. Quelle part des victimes de FIN12 appartient au secteur de la santé ?
4. Quel était le mode d'accès lors de l'incident du CHU de Brest ?
5. Quel est le délai de chiffrement approximatif pratiqué par FIN12 ?

Réponses : **1.** 6 · **2.** Rclone · **3.** ≥ 20 % · **4.** RDP (identifiants volés par information stealer) · **5.** ~4 jours

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.